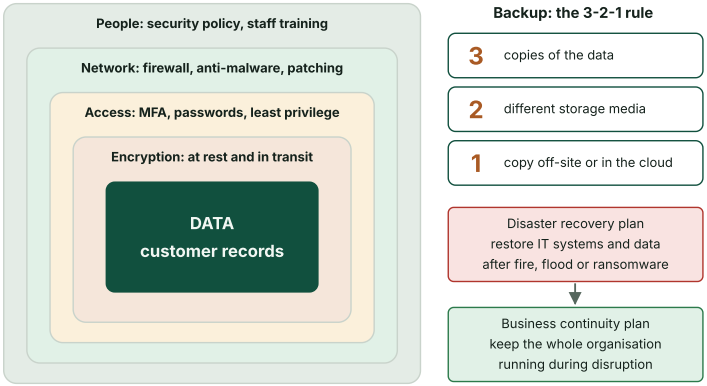
Protecting systems: security measures, backup methods and disaster recovery

AP15 FACT FILE

Specification: students should be able to

- Describe the purpose and content of a security policy
- Describe access control and authentication methods, encryption and firewalls
- Evaluate methods of backup: full backup, differential backup and incremental backup
- Describe how a system is restored using each method of backup
- Explain the purpose of a disaster recovery plan
- Describe the contents of a typical disaster recovery plan, including recovery point and recovery time objectives, and how plans are tested

Key words: security policy, authentication, multi-factor authentication, access rights, encryption, firewall, full backup, differential backup, incremental backup, off-site backup, downtime, disaster recovery, disaster recovery plan, recovery point objective (RPO), recovery time objective (RTO), business continuity plan



Layers of protection around data – policy and training, network defences, authentication and access rights, encryption – alongside the 3-2-1 backup rule and disaster recovery

Overview: layers of protection and a plan for recovery

No single measure keeps data safe, so organisations use layers. Some measures are procedural, such as a security policy that tells staff how to handle data, choose passwords and report incidents. Others are technical: authentication proves that users are who they claim to be, access rights limit what each user can do, encryption makes intercepted or stolen data unreadable, and firewalls filter network traffic. Physical measures, such as locked server rooms, protect the hardware itself. Even with all of these, data can still be lost through hardware failure, human error, ransomware or a flood, so every organisation also needs to be able to recover. That depends on a sensible backup strategy, using full, differential or incremental backups, and on knowing exactly how to restore from them. For serious incidents that knock out whole systems or buildings, a documented disaster recovery plan sets out what must be restored first, how quickly, by whom and from where. This lesson covers the protective measures, evaluates the three methods of backup, explains how systems are restored, and describes the purpose and contents of a disaster recovery plan.

Security policy, authentication and access rights

A security policy is a formal document that sets out the rules, procedures and responsibilities an organisation uses to protect its systems and data. It normally covers acceptable use of equipment and the internet, password requirements, who may access which data, the use of personal devices and removable media, remote working, how to report incidents, backup procedures and the training staff will receive, along with the consequences of breaking the rules. It must be communicated, enforced and reviewed. Access control then turns the policy into practice. Users first identify themselves and then authenticate using something they know, something they have or something they are. Multi-factor authentication combines at least two of these factor types, so an attacker who has phished a password still cannot log in without, for example, the user's phone. Once logged in, access rights determine what each user may do, such as read-only or read and write, and to which files. Following the principle of least privilege limits the damage caused by mistakes, malicious insiders or a compromised account, and audit logs help detect misuse.

Encryption and firewalls

Encryption applies an algorithm and a key to plaintext to produce ciphertext, which cannot be understood without the correct key. In symmetric encryption the same key encrypts and decrypts, which is fast but creates the problem of sharing the key safely. Asymmetric encryption uses a key pair: anyone can encrypt with the public key, but only the holder of the matching private key can decrypt. In practice, asymmetric encryption is used when a secure web connection is set up to agree a symmetric session key, which then encrypts the rest of the traffic. Encryption protects data in transit, such as HTTPS and virtual private networks, and data at rest, such as laptop drives, USB sticks and backups. It does not stop data being stolen or deleted; it stops stolen data being read. A firewall examines incoming and outgoing traffic against a set of rules, such as permitted IP addresses, ports and protocols, and blocks anything that does not match. Hardware firewalls guard the boundary of a network, while software firewalls protect individual devices. Anti-malware software and prompt patching complete the technical defences.

Full, differential and incremental backups

A full backup copies every file on the system. It is the simplest to restore, because the whole system comes back from a single backup, but it takes the longest to create and uses the most storage, and since only a small fraction of data usually changes each day, most of the copying is repeated work. Many organisations therefore take a full backup weekly and combine it with one of the other methods. A differential backup copies every file altered after the most recent full backup. It is quicker to create than a full backup, and a restore needs only two backups, but each differential is larger than the one before because changes keep accumulating until the next full backup. An incremental backup copies only the files modified after the most recent backup, whatever its type. It is the fastest to create and needs the least storage, but restoring requires the full backup plus every incremental since, applied in order, so it is the slowest and most complex restore. If any one incremental in the chain is corrupt or missing, later changes cannot be recovered reliably. The best choice depends on how much data changes, the storage available and how quickly the system must be back.

Restoring systems

A backup is only useful if the organisation can restore from it efficiently, so the restore process must be planned to keep downtime to a minimum. With full backups, the existing files are simply replaced with the most recent full copy, which is straightforward and usually the quickest option. With differential backups, the last full backup is restored first and then the most recent differential is applied; unchanged files come from the full backup and changed files from the differential, which always holds the newest backed-up version of each changed file. With incremental backups, the last full backup is restored and then every incremental made since is applied in date order. A file may have changed several times, so it may appear in several incrementals, and applying them in order ensures that the latest version ends up in place. In every case the system is then at the state of the last restore point. Any work done after that point is lost unless it was captured in a transaction log, in which case the logged transactions are re-applied to bring the data fully up to date. Restores should be practised regularly so staff know the procedure and can be confident the backups actually work.

Disaster recovery plans

Disaster recovery is the process by which an organisation recovers its IT systems after a catastrophic event, something much more serious than a single failed disk or deleted file. Disasters may be accidental, such as a fire or widespread data corruption, natural, such as flooding or storm damage, or deliberate, such as a major cyber attack or terrorism. They cannot be prevented, so a disaster recovery plan does not try to avoid them; its purpose is to minimise their effects and allow the organisation to resume operating quickly with as little disruption to customers as possible. The plan should be drawn up when a system is introduced and kept up to date. At a minimum it identifies the critical data, the key personnel and their responsibilities, the backup and recovery processes, and a fallback location where work can carry on. The organisation then lists the systems that must be recovered, ranked by importance, and sets a time limit for recovering each one. Techniques to meet those limits include off-site or cloud backups, private online storage, cloud-hosted servers that can be activated on demand and staff on standby. A wider business continuity plan covers keeping the whole organisation running, not just its IT.

Recovery objectives and testing

The CCEA textbook describes the recovery point objectives as the list of parts of the system that must be restored after a disaster, and the recovery time objectives as the time limit for recovering each of them. A retailer might set 12 hours to restore its online shop but five days for payroll, because the shop earns money every hour while staff are paid monthly. In wider industry use, the recovery point objective is usually expressed as the maximum amount of data, measured in time, that the organisation can afford to lose; an RPO of one hour means backups or replication must happen at least hourly. Both views lead to the same practical point: the most critical functions get the highest priority and the most expensive protection. A plan that has never been tested may fail when it is needed, so testing is essential. In a walk-through or theoretical test, participants step through the plan to check that everyone knows their role and that contact details and procedures are correct. In a simulation test, working systems are deliberately disabled and actually recovered, so weaknesses such as missing backups or unrealistic time limits are found and fixed before a real disaster.

T Key terms from the mark schemes

Security policy
A formal document setting out the rules, procedures and responsibilities an organisation uses to protect its systems and data.

Authentication
The process of proving that a user is who they claim to be, using something they know, have or are.

Multi-factor authentication (MFA)
Authentication requiring two or more different types of evidence, such as a password and a code sent to a phone.
`Credited: two-factor authentication (2FA)`

Encryption
Converting plaintext into ciphertext using an algorithm and a key so that it cannot be understood without the correct key.

Firewall
Hardware or software that monitors network traffic and blocks data that does not meet a set of security rules.

Full backup
A backup that copies every file on the system, whether or not it has changed, each time it runs.

Differential backup
A backup that copies every file altered after the most recent full backup, so it grows until the next full backup.

Incremental backup
A backup that copies only files modified after the most recent backup of either kind, full or incremental.

Disaster recovery plan
A documented plan setting out how an organisation will restore its IT systems and data and resume operating after a catastrophic incident such as fire, flood or a cyber attack.
`Credited: DR plan`

Recovery point objective (RPO)
In the CCEA textbook, the list of parts of the system that must be restored after a disaster; more widely, the maximum amount of data, measured in time, that can acceptably be lost.
`Credited: RPO`

Recovery time objective (RTO)
The time limit within which each part of the system must be recovered after a disaster.
`Credited: RTO`

Downtime
The period during which a system is not operational and cannot be used.

Exam focus

Backup questions often ask you to describe how each method works and give advantages and disadvantages, so learn a precise definition of each: incremental copies changes since the last backup of any type, while differential copies changes since the last full backup. Mixing these up is the most common error. For evaluate questions, compare backup time, storage needed, restore time and the risk of a broken chain, then make a justified recommendation for the scenario. Recovery questions in a context, such as a failure part-way through the week, reward a clear sequence: restore the last full backup, then the relevant differential or each incremental in order, state which point in time the system is now at, then re-apply logged transactions. For disaster recovery plans, the four contents usually credited are the critical data, the key staff, how backups are taken and restored, and a fallback site. When defining RPO and RTO, give the textbook meaning and support it with an example. For security measures, say how the measure works and which threat it counters, and remember that encryption makes stolen data unreadable rather than preventing theft.

? Check yourself

1. State three items that would be included in an organisation's security policy. [3]
2. A Northern Ireland bank asks customers to enter a password and then a code sent to their phone. Explain how this multi-factor authentication improves security. [2]
3. Describe the difference between symmetric and asymmetric encryption. [2]

Answers: 1. Any three from: acceptable use of equipment and internet (1) / password rules (1) / access levels for different staff (1) / use of personal devices and removable media (1) / remote working rules (1) / procedure for reporting incidents (1) / backup procedures (1) / staff training (1) / disciplinary consequences of breaches (1). 2. It requires two different types of evidence, something the customer knows and something they have (1); so a criminal who has stolen or phished the password still cannot log in without the customer's phone (1). 3. Symmetric encryption uses the same key to encrypt and decrypt (1); asymmetric uses a public key to encrypt and a different, matching private key to decrypt (1).